Die KI-Verordnung – Überblick über den neuen Rechtsrahmen

Rechtsanwalt Dr. Kuuya Chibanguza und Dr. Dr. Hans Steege[*]

Die kürzlich verabschiedete KI-Verordnung (AI-Act) ist das weltweit erste Gesetz, das Künstliche Intelligenz reguliert. Die Bedeutung dieser Verordnung kann nicht hoch genug eingeschätzt werden, da es in naher Zukunft fast keine Branche geben wird, die nicht erheblich von Künstlicher Intelligenz beeinflusst werden wird. Der Beitrag gibt einen praxisbezogenen Überblick über die wesentlichen Inhalte der KI-Verordnung.

I. Einleitung

1 Die „Verordnung zur Festlegung harmonisierter Vorschriften für Künstliche Intelligenz" ist ein ambitioniertes Gesetz. Es soll der Regulierung hochkomplexer Technologie dienen, die eine hohe gesellschaftliche und grundrechtliche Relevanz hat und die gleichzeitig hinsichtlich ihrer Potenziale und Risiken aufgrund fehlender Empirie noch eine Blackbox ist. Nachdem die Europäische Kommission am 21.4.2021 einen Entwurf veröffentlicht hatte,[1] wurden teilweise stärkere Einschränkungen und eine strengere Regulierung beim Einsatz von Künstlicher Intelligenz (KI) gefordert. Demgegenüber wurde im juristischen Schrifttum kritisiert, dass aufgrund zahlreicher unbestimmter Rechtsbegriffe für Unternehmen eine erhebliche Rechtsunsicherheit folgt und die Regulierung zu weitreichend ist. Die Beteiligung an den öffentlichen Konsultationen war auch aufseiten der Interessenverbände äußerst groß. Wohl auch deshalb dauerte es 19 Monate, bis der EU-Rat im November 2022 seinen Regulierungsvorschlag vorlegte[2] und sieben weitere Monate, bis sich auch das EU-Parlament auf eine gemeinsame Position einigen konnte.[3] Erst im Juni 2023 begann der sogenannte Trilog, in welchem sich die gesetzgebenden Institutionen am 8.12.2023 nach intensiven Verhandlungen und unter großem Druck, wohl nicht zuletzt aufgrund der anstehenden Neuwahlen des Europaparlaments, politisch über die zukünftigen Regelungsinhalte einigen konnten. Der Einigungstext vom 21.1.2024 wurde geleakt. Diese Einigung wurde am 2.2.2024 nach weiteren politischen Debatten, auch innerhalb der deutschen Bundesregierung, von den Mitgliedstaaten akzeptiert. Sie wurde am 13.3.2024 durch das EU-Parlament verabschiedet. Am 21.5.2024 hat der EU-Rat die KI-VO beschlossen, so dass derzeit lediglich noch die Veröffentlichung im Amtsblatt der EU aussteht. Die KI-VO tritt am 20. Tag nach ihrer Verkündung im Amtsblatt der EU in Kraft (Art. 113 KI-VO). Ab diesem Zeitpunkt sind gestufte Umsetzungsfristen vorgesehen (sechs, zwölf, 24, 36 Monate), wobei im Grundsatz eine 24 Monate lange Umsetzungsfrist (Art. 113 KI-VO) gilt.

2 Zweck der Verordnung ist, wie Art. 1 I KI-VO klarstellt, die Stärkung des gesamtgesellschaftlichen Vertrauens in KI. Zu diesem Zweck werden Compliance-Anforderungen an KI-Systeme gestellt, die umso strenger sind, je stärkere Grundrechtseingriffe drohen. Mit diesem risikobasierten Ansatz stellt die KI-VO aus Sicht des Gesetzgebers eine angemessene Reaktion auf zukünftige technische Entwicklungen dar. Für Unternehmen stellt sich vor allem die Frage, welche Anforderungen sie erfüllen müssen, wenn sie eigens oder fremdentwickelte KI-Systeme einsetzen wollen. Die Implementierung eines Compliance-Managementsystems ist dabei ebenso mit Herausforderungen verbunden, wie die formelle Durchführung des Zertifizierungsverfahrens.

II. Überblick über die wesentlichen Regelungsinhalte

1. KI-Definition

3 Zentrales Merkmal der KI-VO ist die in Art. 3 Nr. 1 KI-VO enthaltene Definition von Künstlicher Intelligenz, welche maßgeblich für den sachlichen Anwendungsbereich und dementsprechend weichenstellend für die konkreten Anforderungen bei der Entwicklung und beim Einsatz von KI

ist.[4] Die KI-Definition zählte zu den umstrittensten Punkten im Gesetzgebungsverfahren. Letztendlich konnte sich ein Vorschlag durchsetzen, der an die Definition der OECD[5] angelehnt ist und somit vor allem eine internationale Anknüpfung gewährleistet:[6]

„(Ein KI-System ist) ein maschinengestütztes System, das für einen in unterschiedlichem Grade autonomen Betrieb ausgelegt ist und das nach seiner Betriebsaufnahme anpassungsfähig sein kann und das aus den erhaltenen Eingaben für explizite oder implizite Ziele ableitet, wie Ausgaben wie etwa Vorhersagen, Inhalte, Empfehlungen oder Entscheidungen erstellt werden, die physische oder virtuelle Umgebungen beeinflussen können."

4 Der im Gesetzgebungsverfahren immer wieder geäußerten Kritik, die Definition sei zu weit und würde auch herkömmliche Software umfassen,[7] da sie keinen ausreichenden Bezug auf KI-typische Elemente[8] wie Multikausalität, Opazität und Autonomie nehme,[9] soll nun durch eine Klarstellung in Erwgr. 12 begegnet werden. Dort heißt es, dass ausdrücklich keine Software vom KI-Begriff umfasst sei, die auf Grundlage von Menschen aufgestellter Regeln eine Aufgabe automatisch ausführt. Vielmehr setze, wie Erwgr. 12 klarstellt, die Klassifizierung als „Künstliche Intelligenz" ein Element des eigenständigen Schlussfolgerns voraus: „Ein wesentliches Merkmal von KI-Systemen ist ihre Fähigkeit, abzuleiten."

5 Die KI-typischen Aspekte des maschinellen Lernens werden mithin durch den Begriff *„ableiten"* abgedeckt. Das schließt jedenfalls einfache Softwaremodelle aus, setzt allerdings nach wie vor keine klare Grenze, in welchem Ausmaß die betreffende Software tatsächlich Schlussfolgerungen frei von menschlicher Intervention ziehen muss, um als KI zu gelten.[10] Insbesondere hinsichtlich komplexerer Software wie Hybrid-KI-Systemen mit Deep-Learning-Elementen ist nicht eindeutig nachvollziehbar, ob und in welchem Maße diese in den Anwendungsbereich fallen.

6 Auch das KI-typische Element der Autonomie findet sich sowohl in Art. 3 Nr. 1 KI-VO als auch in Erwgr. 12 wieder, in welchem es heißt: „KI-Systeme sind mit verschiedenen Graden der Autonomie ausgestattet, was bedeutet, dass sie bis zu einem gewissen Grad unabhängig von menschlichem Zutun agieren und in der Lage sind, ohne menschliches Eingreifen zu arbeiten."

7 Die geforderte Autonomie trägt allerdings vor dem Hintergrund der ebenfalls geforderten Fähigkeit zur Schlussfolgerung nicht zur weiteren Differenzierung zwischen KI und regulärer Software bei, da eine eigenständige Schlussfolgerung per definitionem eine gewisse Autonomie voraussetzt.[11] Zudem wird kein Mindestmaß an Autonomie gefordert, sondern eine ganze Spannbreite erfasst.

2. Anwendungsbereich

8 Aufgrund der digitalen Natur von KI-Systemen und der Möglichkeit der fortwährenden Weiterentwicklung während des Betriebs ist das Ziehen von eindeutigen Grenzen hinsichtlich der Anwendbarkeit der KI-VO mitunter schwierig.

a) Zeitlicher Anwendungsbereich

9 In zeitlicher Hinsicht verfolgt die KI-VO das Ziel, KI während ihres gesamten Lebenszyklus' zu regulieren.[12] Das heißt, dass die KI-VO nicht nur Anforderungen an die Entwicklung von KI aufstellt, sondern auch zahlreiche Pflichten nach dem Inverkehrbringen, beispielsweise Überwachungspflichten, vorsieht. Aus Sicht des Produktsicherheits- und Produkthaftungsrechts sind Anforderungen an den Marktzutritt und nach der Inverkehrgabe nicht neu. Das Bestehen einer Produktbeobachtungspflicht nach dem Inverkehrbringen ist seit jeher Bestandteil des Produkthaftungsrechts.[13] Die Anforderungen an die Produktbeobachtung können in Anbetracht der kontinuierlichen Weiterentwicklung des KI-Systems sowie in Anbetracht verschiedener Einsatz- und Kombinationsmöglichkeiten höher ausfallen.[14]

b) Persönlicher Anwendungsbereich

10 Der persönliche Anwendungsbereich erfasst Anbieter („Provider") und Betreiber („Deployer").

11 Anbieter ist gem. Art. 3 Nr. 3 KI-VO „eine natürliche oder juristische Person, Behörde, Einrichtung oder sonstige Stelle, die ein KI-System oder ein KI-Modell mit allgemeinem Verwendungszweck entwickelt oder entwickeln lässt und es unter ihrem eigenen Namen oder ihrer Handelsmarke in Verkehr bringt oder das KI-System unter ihrem eigenen Namen oder ihrer Handelsmarke in Betrieb nimmt, sei es entgeltlich oder unentgeltlich". Umfasst sind also nicht nur die Entwickler und Hersteller von KI, sondern auch jene Akteure, die eine KI anfertigen lassen und diese dann unter ihrem eigenen Namen auf den Markt bringen.[15]

12 Anbieter sind die Hauptadressaten der Anforderungen aus der KI-VO. Vor allem große Unternehmen, die eine Fremdentwicklung beauftragen und diese selber betreiben, können so Anbieter im Sinne der KI-VO werden. In der Praxis kann dies aufgrund der zahlreichen Vorgaben nachteilig sein, insbesondere da das Tatbestandsmerkmal der Inverkehrgabe auch den internen Einsatz erfasst und nicht voraussetzt, dass das KI-System extern betrieben wird. Daher kann es von Vorteil sein, nicht nur die Entwicklung, sondern auch den Betrieb durch den Dritten zu beauftragen. Insofern werden vertragliche und gesellschaftsrechtliche Gestaltungsmöglichkeiten relevant, um die Stellung als Anbieter zu umgehen.

13 Betreiber ist nach Art. 3 Nr. 4 KI-VO „eine natürliche oder juristische Person, Behörde, Einrichtung oder sonstige Stelle, die ein KI-System in eigener Verantwortung verwendet, es sei denn, das KI-System wird im Rahmen einer persönlichen und nicht beruflichen Tätigkeit verwendet". Vom Anwendungsbereich ausgenommen ist der private, das heißt nicht berufsmäßige Gebrauch von KI-Systemen, ähnlich Art. 2 II Buchst. c DS-GVO. Darunter fällt etwa die private Nutzung von Tools wie ChatGPT.

c) Räumlicher Anwendungsbereich

14 Der räumliche Anwendungsbereich umfasst gem. Art. 2 I Buchst. a KI-VO Anbieter, die in der Union ein KI-System oder ein System mit allgemeinem Verwendungszweck (sog. General Purpose AI oder GPAI), in den Verkehr bringen oder es dort in Betrieb nehmen. Außerdem umfasst er Betreiber, die ihren Sitz in der Union haben. Neben dem Niederlassungsprinzip findet auch das Marktortprinzip Anwendung. Die KI-VO adressiert also auch Anbieter und Betreiber, die ihren Sitz zwar in einem Drittstaat haben, deren KI-System aber in der Union wirkt.[16] So soll verhindert werden, dass Unternehmen in Drittstaaten die Anforderungen der KI-VO nicht beachten müssen.[17]

3. Risikobasierter Ansatz der KI-VO

15 Die KI-VO verfolgt einen risikobasierten Ansatz, so dass der Umfang der Regulierung von der Intensität der vom KI-System ausgehenden Risiken abhängt.[18]

16 Anhand verschiedener Kriterien, die ausschlaggebend für die jeweilige Risikoklassifizierung sind, werden KI-Systeme vom Gesetzgeber in verbotene KI-Praktiken (Art. 5 KI-VO), Hochrisiko-KI-Systeme (Art. 6 KI-VO), KI-Systeme mit beschränktem Risiko (Art. 50 KI-VO) und KI-Systeme mit geringem Risiko (Art. 95 KI-VO) unterteilt. Daneben stehen KI-Systeme mit allgemeinem Verwendungszweck (Art. 51 ff. KI-VO).

17 Unternehmen müssen daher zunächst prüfen, ob ein KI-System vorliegt und sodann, um welche Art von KI-System es sich handelt, um zu wissen, welche Anforderungen sie einhalten müssen.

III. Arten von KI-Systemen und deren Anforderungen

18 Zunächst stellt die KI-VO risikoklassenübergreifend generelle Pflichten auf, die im Umgang mit KI gelten. Nach Art. 4b KI-VO müssen Anbieter und Betreiber Maßnahmen ergreifen, um sicherzustellen, dass ihre Mitarbeiter oder sonstige Personen, die in ihrem Auftrag ein KI-System nutzen, über einen hinreichenden Grad an Verständnis in Bezug auf jenes System verfügen („AI literacy" bzw. „KI-Kompetenz"), um ein Bewusstsein für die Risiken und Potenziale zu entwickeln und so informierte Entscheidungen zu treffen.[19] Dabei verlangt die Verordnung vor allem ausreichende technische Erfahrung und Kenntnisse in Bezug auf KI, wobei bei den Anforderungen die Personen oder die Personengruppe, die das KI-System letztendlich nutzen, zu berücksichtigen sind. Wie sich aus Erwgr. 8 KI-VO ergibt, sollen durch eine solche KI-Kompetenz Anbietern und Betreibern mögliche Risiken bezüglich der Grundrechte, Gesundheit und Sicherheit anderer aufgezeigt werden. Der Umfang dieser Kompetenz ist abhängig vom Einzelfall und richtet sich nach dem Grad des Risikos des KI-Systems. Eine solche Instruktions- und Schulungspflicht ermöglicht einen eigenverantwortlichen Umgang mit den inhärenten Risiken.

19 Im Folgenden sollen die verschiedenen KI-Systeme sowie grundlegende Anforderungen dargestellt werden.

1. Verbotene Praktiken

20 In Art. 5 KI-VO werden Praktiken aufgezählt, deren Einsatz verboten ist. Der europäische Verordnungsgeber geht davon aus, dass die von ihnen ausgehende Gefahr für die Grundrechte der Betroffenen zu gravierend ist, um eine Nutzung zu genehmigen. Nicht verboten ist, resultierend aus der Wissenschaftsfreiheit, Forschung zu solchen Praktiken.[20]

21 Nach Art. 5 I Nr. 1 Buchst. a KI-VO ist das Inverkehrbringen, die Inbetriebnahme sowie die Verwendung von KI zur unterschwelligen Beeinflussung außerhalb des Bewusstseins eines Menschen verboten, wenn die Beeinflussung wesentlich ist und darauf abzielt, dieser oder einer anderen Person einen physischen oder psychischen Schaden zuzufügen. Entscheidend ist in diesem Zusammenhang, dass das KI-System auf eine Manipulation oder Bewusstseinsbeeinflussung abzielen muss. Dies dürfte in vielen Fällen zumindest nur sehr schwer nachzuweisen sein,[21] was der Praktikabilität der Vorschrift entgegen steht.[22]

22 Ebenso sind nach Art. 5 I Nr. 1 Buchst. b KI-VO Systeme verboten, die die Schutzbedürftigkeit einer Person oder einer Gruppe aufgrund ihres Alters, ihrer Behinderung, ihrer sozialen oder wirtschaftlichen Situation ausnutzen, um deren Verhalten dahingehend zu beeinflussen, dass diese sich oder anderen Personen einen erheblichen Schaden zufügt oder mit hinreichender Wahrscheinlichkeit zufügen wird. Ebenfalls erforderlich ist die Beeinflussungsabsicht, so dass wie bei Art. 5 I Nr. 1 Buchst. a KI-VO der Nachweis schwer möglich ist.

23 Unter dem Schlagwort „Social Scoring" sind gem. Art. 5 I Nr. 1 Buchst. c KI-VO Systeme verboten, die eine natürliche Person oder eine Gruppe von Personen aufgrund ihres sozialen Verhaltens oder auf Grundlage von Eigenschaften sowie Persönlichkeitsmerkmalen bewerten oder klassifizieren. Dabei darf die Schlechterstellung oder Benachteiligung jener Menschen nicht entgegen des Zwecks der ursprünglichen Datenerfassung erfolgen oder ungerechtfertigt oder unverhältnismäßig sein. In den Vorschlägen des EU-Parlaments und des EU-Rats sollte dieses Verbot nur für Behörden und solche Privatakteure gelten, die im behördlichen Auftrag handeln. Diese Einschränkung wurde nicht aufgenommen.

24 Einer der umstrittensten Punkte im Gesetzgebungsverfahren, sowohl auf Unionsebene als auch innerhalb der deutschen Bundesregierung, war das Ausmaß, in dem die Verwendung biometrischer Echtzeit-Fernidentifizierungssysteme erlaubt sein sollte. Das Ergebnis ist ein Zusammenspiel von Verboten, Ausnahmen und Rückausnahmen. Grundsätzlich gelten biometrische Echtzeit-Fernidentifizierungssysteme nach der KI-VO als Hochrisiko-KI-System, was im Umkehrschluss bedeutet, dass sie grundsätzlich nicht zu den verbotenen KI-Praktiken zählen. Art. 5 I Nr. 1 Buchst. d KI-VO verbietet jedoch den Einsatz dieser Systeme zum Zwecke der

Strafverfolgung. Dieses Verbot gilt jedoch nur, wenn keiner der ebenfalls dort gelisteten Ausnahmetatbestände vorliegt, namentlich die gezielte Suche von vermissten Personen oder Opfern bestimmter Straftaten, die Prävention einer bestimmten Gefahr für Leib und Leben oder einer terroristischen Gefahr sowie die Lokalisierung oder Identifikation des potenziellen Täters einer in Anhang II gelisteten Straftat. Die Vorschriften der KI-VO stellen keine Rechtsgrundlage für die Durchführung einer biometrischen Echtzeit-Fernidentifizierung dar, sondern statuieren lediglich ein Mindestmaß an Schutz, den die Mitgliedstaaten bei der Schaffung eigener Rechtsgrundlagen beachten müssen. Hinzu kommt, dass beispielsweise die Datenverarbeitung einer Rechtsgrundlage im Sinne der DS-GVO bedarf.

25 Die Vorgaben bezüglich einer nachträglichen Nutzung der mittels biometrischer Fernidentifikation erhobenen Daten sind recht weit. Grundsätzlich ist eine nachträgliche Nutzung der Daten uneingeschränkt möglich, da es sich nicht mehr um eine Echtzeit-Fernidentifizierung iSd Art. 3 I Nr. 35 KI-VO handelt, welche nur bei einem Abgleich oder einer Identifizierung in Echtzeit vorliegt. Allerdings sind auch hier Vorgaben aus anderen Rechtsgebieten, wie etwa dem Datenschutz, zu beachten.

26 Für die Einhaltung des Art. 5 KI-VO gilt nach Art. 113 KI-VO eine Umsetzungsfrist von sechs Monaten ab Inkrafttreten der Verordnung.

27 Der Einsatz verbotener Praktiken wird streng sanktioniert. Gemäß Art. 99 III KI-VO kann ein Bußgeld von bis zu 35 Mio. EUR verhängt werden, alternativ (bei Unternehmen) von bis zu 7% des weltweiten Jahresumsatzes, je nachdem, was im Einzelfall höher ist.

2. Hochrisiko-KI-Systeme

28 Hochrisiko-KI-Systeme stellen das Herzstück der KI-VO dar; die Anforderungen an diese sind umfassend.

a) Vorliegen eines Hochrisiko-KI-Systems

29 Eine Legaldefinition für Hochrisiko-KI-Systeme hat der europäische Gesetzgeber nicht vorgesehen, vielmehr wird auf ein dynamisches System gesetzt, das in den Art. 6 und Art. 7 KI-VO seinen normativen Anknüpfungspunkt findet.

30 Gemäß Art. 6 I KI-VO liegt ein Hochrisiko-KI-System vor, wenn es als Sicherheitskomponente für ein anderes Produkt verwendet wird oder wenn es selbst ein Produkt ist, das bestimmten, in Anhang II aufgeführten, EU-Regulierungen unterliegt.

31 Art. 6 II KI-VO ordnet zudem Lebenssachverhalte bzw. Anwendungsbereiche als derart schützenswert ein, dass in diesen Bereichen eingesetzte Systeme ein Hochrisiko-System darstellen. Diese sind in Anhang III aufgezählt. Umfasst ist etwa die Verwendung am Arbeitsplatz und beim Personalmanagement sowie der Einsatz im Zusammenhang mit grundlegenden privaten und öffentlichen Leistungen. KI-Systeme, die in die betreffenden Anwendungsbereiche fallen, können gem. Art. 6 III KI-VO von der Klassifizierung als Hochrisiko-KI-System ausgenommen werden, wenn von ihnen kein erhebliches Risiko für die Schädigung der Gesundheit, Sicherheit oder Grundrechte von natürlichen Personen ausgeht und wenn sie keinen wesentlichen Einfluss auf Entscheidungsprozesse haben, weil sie nur untergeordnete Hilfstätigkeiten erfüllen. Ob dieser Ausnahmetatbestand erfüllt ist, können die Anbieter selbst beurteilen, müssen dies aber nach Art. 6 IV KI-VO ordnungsgemäß dokumentieren und das KI-System gleichwohl gem. Art. 49 II KI-VO registrieren. Dass hierbei kein behördliches Verfahren notwendig ist, ist begrüßenswert, da Verwaltungsaufwand für Unternehmen und Behörden vermieden wird. Das Risiko einer fehlerhaften Beurteilung führt für Anbieter allerdings zu einem Haftungsrisiko. Aber auch für Betreiber wirkt sich die fehlerhafte Einschätzung nachteilig aus, da es keine Kontrollpflicht gibt und dadurch Anforderungen an Hochrisiko-KI-Systeme aufgrund der fehlerhaften Annahme nicht eingehalten werden. Betreiber sollten die Prüfung durch Anbieter kritisch hinterfragen und sich die Dokumentation zur Kontrolle vorlegen lassen. Wie weit eine solche Kontrollpflicht reicht, wird sich zeigen.

32 In Art. 7 I KI-VO wird die EU-Kommission dazu ermächtigt, den Katalog der Lebenssachverhalte bzw. Anwendungsbereiche in Anhang III um weitere Anwendungsfälle zu ergänzen bzw. die bestehende Liste zu ändern. So behält sich der Gesetzgeber vor, bei Bedarf flexibel auf technische Entwicklungen zu reagieren. Um die Klassifizierung zu erleichtern, ist die Kommission zudem angehalten, innerhalb von 18 Monaten nach Inkrafttreten der Verordnung eine Liste mit Beispielen und Gegenbeispielen zusammenzustellen.

b) Anforderungen an Hochrisiko-KI-Systeme

33 In den Art. 8 ff. KI-VO werden die Compliance-Voraussetzungen für Hochrisiko-KI-Systeme definiert. Zentrales Element ist hierbei die in Art. 9 KI-VO generalklauselartig vorangestellte Pflicht zur Einrichtung eines Risikomanagementsystems, das den gesamten Lebenszyklus der KI umfasst. Die Risikoanalyse soll hierbei die Gefahren im Hinblick auf Gesundheit, Sicherheit oder Grundrechte berücksichtigen, die das KI-System bei einer mit dem vorgesehenen Zweck übereinstimmenden Verwendung mit sich bringt. Allerdings soll auch ein naheliegender Missbrauch berücksichtigt werden. In den folgenden Artikeln werden Anforderungen an die Data-Governance (Art. 10 KI-VO), an die Erstellung und Aufbewahrung technischer Dokumentation (Art. 11 und 12 KI-VO), an die Informationsbereitstellung (Art. 13 KI-VO) sowie an die Genauigkeit, Robustheit und Cybersicherheit (Art. 15 KI-VO) des Systems gestellt. Im Mittelpunkt der Anbieterpflichten steht überdies die Sicherstellung menschlicher Aufsicht über die KI (Art. 14 KI-VO), wobei vor allem die Herstellung einer „Mensch-Maschine-Schnittstelle" elementar ist.[23]

34 Die während des Gesetzgebungsverfahrens vom Parlament vorgeschlagene allgemeine Pflicht zur Durchführung einer Grundrechte-Folgenabschätzung („Fundamental Rights Impact Assessments") besteht gem. Art. 27 KI-VO ausdrücklich nur noch für staatliche Akteure und Privatakteure, die staatliche Aufgaben durchführen. Es ist allerdings unklar, in welchem Maße diese rein grundrechtsbezogene Risikobewertung über die allgemeine Risikobewertung im Rahmen des Art. 9 KI-VO hinausgehen soll, bei der die Verletzung von Grundrechten ebenfalls ein relevanter Abwägungsfaktor ist.[24]

35 Die konkreten Anforderungen an Anbieter ergeben sich aus Art. 16 KI-VO. Unter bestimmten Voraussetzungen

können Pflichten für Anbieter auch für Betreiber gelten. Dies ist gem. Art. 25 KI-VO der Fall, wenn sie ein in Verkehr befindliches Hochrisiko-KI-System mit einem Namen oder eigener Marke versehen, wenn sie eine wesentliche Änderung vornehmen oder wenn Betreiber den Zweck der KI ändern. Wann eine wesentliche Änderung eines KI-Systems vorliegt, ist unklar. Teilweise wird gefordert, dass daran kein strenger Maßstab angelegt werden soll, um die Akteure entlang der KI-Lieferkette nicht infolge leichter Modifikationen den strengen Anforderungen an Anbieter zu unterwerfen.[25] Allerdings ist bei der Beurteilung, wann eine wesentliche Änderung vorliegt, der Wortlaut des Art. 3 Nr. 23 KI-VO als Grenze zu beachten, in dem die „wesentliche Änderung" legaldefiniert ist.

36 In den Fällen des Art. 25 KI-VO geht die Verantwortlichkeit für die Compliance (Art. 25 II KI-VO) vom ursprünglichen auf den neuen Provider über. Er ist jedoch nach Art. 28 II 2 KI-VO dazu verpflichtet, dem neuen Anbieter alle Dokumentationen und Unterlagen bereitzustellen, die für die Erfüllung der nun an ihn zu stellenden Compliance-Anforderungen erforderlich sind. Aus dem Gesetzestext ergibt sich keine konkrete Pflicht hinsichtlich einer Dokumentation der Prüfung, ob eine wesentliche Änderung vorliegt. Eine solche ist allerdings aufgrund der stets vorhandenen Gefahr einer von der Behörde abweichenden Einschätzung unbedingt zu empfehlen. Liegen die Voraussetzungen des Art. 25 KI-VO nicht vor, gilt für Betreiber der weniger umfangreiche Pflichtenkatalog des Art. 26 KI-VO. Art. 72 KI-VO statuiert zudem für Anbieter von Hochrisiko-KI-Systemen Pflichten nach der Inverkehrgabe in Form von Produktbeobachtungspflichten. Insbesondere bei sich weiterentwickelnden Systemen sind die Anforderungen an die Produktbeobachtung höher.

37 Im Zusammenhang mit dem gem. Art. 40 ff. KI-VO notwendigen Konformitätsbewertungsverfahren, also dem Verfahren vor Inverkehrgabe einer Hochrisiko-KI, sind noch viele Details unklar. Es ist noch offen, welche Stellen diese Konformitätsbewertung durchführen. Neben der fachlichen Kompetenz erscheint dabei insbesondere fraglich, wie die Stellen in Zeiten der Personalknappheit mit dem zu erwartenden Ansturm an beantragten Zertifizierungen umgehen können. Auch die Normungsorganisationen sind vor große Herausforderungen gestellt, denn für die meisten Gesichtspunkte, die im Rahmen der Risikoanalyse eines KI-Systems relevant werden, sind noch keine ISO- oder vergleichbare Prüfstandards veröffentlicht.

38 Für Anbieter und Betreiber stellt sich in der Praxis gleichermaßen das Problem, dass die Implementierung eines Compliance-Management-Systems mit hohem Aufwand und hohen Kosten verbunden ist.[26] Dies stellt besonders kleine und mittelständische Unternehmen (KMU) vor große Herausforderungen, weshalb diesen die Möglichkeit gegeben wird, die technische Dokumentation in vereinfachter Form bereitzustellen. Wie dies erfolgen kann, ist noch offen. Die Kommission plant ein Muster zu veröffentlichen.

39 Die an Hochrisiko-KI-Systeme gestellten Anforderungen müssen nach Art. 113 I 2 Buchst. c KI-VO innerhalb von 36 Monaten ab Inkrafttreten erfüllt werden. Sollten sich derartige KI-Systeme bereits auf dem Markt befinden, müssen sie gem. Art. 113 I 1 KI-VO den Vorgaben der Verordnung erst entsprechen, wenn sie nach deren Inkrafttreten eine wesentliche Änderung durchlaufen, so dass ein Bestandsschutz besteht. Die an Hochrisiko-KI-Systeme gestellten Anforderungen unterliegen gem. Art. 113 I 1 KI-VO der allgemeinen Umsetzungsfrist von 24 Monaten, wobei die Ausnahmen nach Satz 2 jeweils zu beachten sind.

40 Verstöße gegen Anforderungen an Hochrisiko-KI-Systeme werden gem. Art. 99 IV KI-VO mit Bußgeldern von bis zu 1,5 Mio. EUR oder (bei Unternehmen) bis zu 3 % des Jahresumsatzes bewehrt, je nachdem, was höher ist.

c) Verhältnis zu Anforderungen aus anderen Rechtsakten

41 Neben die Anforderungen der KI-VO treten Voraussetzungen, die von anderen Vorschriften des Unionsrechts an KI gestellt werden. Die KI-VO stellt insofern keine abschließende Regulierung dieser Technologie dar, sondern fügt sich in den bereits bestehenden Rechtsrahmen ein, ohne diesen zu modifizieren oder zu verdrängen.[27] Insbesondere aus DS-GVO und Data Act können zusätzlich zur KI-VO erhebliche Anforderungen für die Entwicklung und Nutzung einer KI folgen,[28] zumal beispielsweise Art. 5 DS-GVO und Art. 10 III KI-VO in einem Spannungsverhältnis zueinander stehen und bei Einhaltung der Anforderungen aus der einen Verordnung ein Verstoß gegen die andere folgt. Aufgrund der parallelen Anwendbarkeit der beiden Rechtsakte kann eine Kumulierung der Bußgelder nach DS-GVO und KI-VO infrage kommen.[29]

3. KI-Systeme mit beschränktem Risiko

42 Für Anbieter und Betreiber von KI-Systemen mit beschränktem Risiko statuiert Art. 50 KI-VO Transparenzpflichten. Es handelt sich hierbei um Situationen, in denen der Nutzer darüber informiert werden muss, dass er mit einer KI interagiert, um sich effektiv schützen zu können.

43 So müssen KI-Systeme, die mit Menschen in Kontakt treten sollen, vom Anbieter gem. Art. 50 I KI-VO per se auf eine Art und Weise gestaltet werden, dass eine durchschnittlich informierte und aufmerksame Person erkennt, dass sie mit einer KI interagiert. Dies stellt eine Form der Technikgestaltung dar.[30] Von dieser Anforderung erfasst werden Chatbots, deren Nutzung im Kundenservice für praktisch jedes Unternehmen interessant ist.[31] Wenn künstliche Deepfakes, Audios, Videos, Bilder oder Texte durch KI erzeugt werden, müssen diese erkennen lassen, dass sie von einer KI generiert wurden. Die Effektivität der Kennzeichnungspflicht für Deepfakes dürfte fraglich sein, da diese zur Beeinflussung des gesellschaftlichen Diskurses kaum mittels Klarnamen verbreitet werden.

44 Diese Pflichten treffen nach Art. 50 IV KI-VO auch Betreiber, wobei eine Beschränkung für künstlerische und satirische Zwecke besteht, in denen allerdings ebenfalls kenntlich gemacht werden muss, dass es sich um eine Manipulation handelt. Zudem trifft Betreiber eine Informationspflicht beim Einsatz von Emotionserkennungssystemen oder

von Systemen zur biometrischen Kategorisierung (Art. 50 III KI-VO).

45 Verstöße gegen Art. 50 KI-VO sind gem. Art. 99 IV KI-VO mit Bußgeldern von bis zu 1,5 Mio. EUR oder (bei Unternehmen) bis zu 3 % des Jahresumsatzes bewehrt, je nachdem, was höher ist.

4. KI-Systeme mit minimalem Risiko

46 Für KI-Systeme, die weder ein Hochrisiko-KI-System sind noch den Art. 50 KI-VO unterfallen, kann gem. Art. 95 KI-VO freiwillig ein Verhaltenskodex befolgt werden. Der Gedanke hinter dieser Regelung ist, dass die Union und die Mitgliedstaaten Wirtschaftsakteure dazu motivieren sollen, auch in nicht-verpflichtenden Bereichen eine möglichst umfassende KI-Compliance herzustellen, um das allgemeine gesellschaftliche Vertrauen in KI zu stärken.

5. Sonderfall KI-Systeme mit allgemeinem Verwendungszweck

47 KI-Systeme mit allgemeinem Verwendungszweck (General Purpose AI oder GPAI), die im Laufe des Gesetzgebungsverfahrens weitestgehend noch als „Foundation Models" bezeichnet wurde, haben in Art. 51 ff. KI-VO ein eigenes Regelungssystem erhalten, das neben dem gestuften, risikobasierten Ansatz steht. Die Voraussetzungen für diese, für verschiedene Zwecke einsetzbare KI sind zusätzlich zu den Voraussetzungen der jeweiligen Stufe zu erfüllen. Erwähnenswert ist, dass die zusätzlichen Pflichten in Art. 51 ff. KI-VO lediglich für die Anbieter von GPAI gelten. Für

Betreiber resultieren aus dem Einsatz von GPAI keine zusätzlichen Pflichten. Die grundsätzlichen Anbieterpflichten der jeweiligen Risikoart der KI bestehen davon aber unberührt weiter.[32]

48 GPAI ist gem. Art. 3 Nr. 63 Buchst. b KI-VO „ein KI-Modell – einschließlich der Fälle, in denen ein solches KI-Modell mit einer großen Datenmenge unter umfassender Selbstüberwachung trainiert wird –, das eine erhebliche allgemeine Verwendbarkeit aufweist und in der Lage ist, unabhängig von der Art und Weise seines Inverkehrbringens ein breites Spektrum unterschiedlicher Aufgaben kompetent zu erfüllen, und das in eine Vielzahl nachgelagerter Systeme oder Anwendungen integriert werden kann, ausgenommen KI-Modelle, die vor ihrem Inverkehrbringen für Forschungs- und Entwicklungstätigkeiten oder die Konzipierung von Prototypen eingesetzt werden". Hierzu zählen zum Beispiel die, die öffentliche Wahrnehmung von künstlicher Intelligenz prägenden, „Large Language Models" wie ChatGPT oder bildgenerierende KI wie Dall-E.

49 Innerhalb der Regelungssystematik für GPAI wird ebenfalls ein abgestufter Ansatz verfolgt. Alle Anbieter von GPAI müssen auf einer ersten Stufe gem. Art. 53 I Buchst. a KI-VO technische Dokumentationen über Training und Tests vorhalten, das EU-Urheberrecht im Rahmen des Trainings und im Rahmen des KI-generierten Veröffentlichungen beachten und Informationen über die Trainingsdaten bereitstellen. Dazu kommt die in Art. 50 I KI-VO statuierte Kennzeichnungspflicht für GPAI-erzeugte Ton-, Bild-, Video- und Textdateien. Die Anbieter von GPAI mit systemischen Risiko („systemic risk") treffen auf einer zweiten Stufe weitere Pflichten gem. Art. 55 KI-VO. Diese Pflichten umfassen die Anmeldung des GPAI-Systems bei der Kommission, die Erfüllung bestimmter Cybersecurity-Anforderungen und die Durchführung einer allgemeinen Risikountersuchung. Ob ein GPAI-System mit systemischen Risiko vorliegt, bestimmt sich nach der für den Betrieb des Systems notwendigen Rechenleistung. Auch wenn dieser Ansatz grundsätzlich dazu geeignet ist, hinsichtlich des unbestimmten Rechtsbegriffs „systemisches Risiko" eine trennscharfe Abgrenzung durchzuführen, so wird die gewählte Schwelle der notwendigen Rechenleistung teilweise für zu niedrig gehalten, da lediglich die Anbieter der zwei bis drei marktführenden Modelle tatsächlich die Anforderungen der zweiten Stufe erfüllen müssen.[33]

50 Eine Ausnahme besteht bei Open Source-Modellen, also solchen, die allen Nutzern frei zugänglich sind und von diesen modifiziert und weiterverbreitet werden können. Ein wichtiges Augenmerk für die Praxis sollte hierbei darauf liegen, dass eine Monetarisierung ein KI-System automatisch von der Klassifizierung als „Open Source" disqualifiziert. Zweck dieser Ausnahme ist die Förderung von Forschung, Innovation und Wettbewerb. Rückausnahmen bestehen allerdings in allen Fällen, in denen durch den Einsatz von Open-Source-Modellen die ansonsten von der KI-VO an Systeme der jeweiligen Klassifizierung gestellten Anforderungen unterlaufen werden könnten. Die infolge dieser umfangreichen Rückausnahmen tatsächlich verbleibende Privilegierung von Open-Source-KI ist letztendlich gering.[34]

51 Die an GPAI gestellten Anforderungen müssen gem. Art. 113 I 2 Buchst. b KI-VO binnen zwölf Monaten nach Inkrafttreten umgesetzt werden. Für GPAI, die bereits vor Erlass der Verordnung in Verkehr gebracht wurde, gilt eine verlängerte Frist von 24 Monaten.

IV. KI-Governance – Marktüberwachung und Sanktionierung

52 Die Marktüberwachung von KI ist auf zwei Ebenen vorgesehen. Zum einen sollen ausweislich der Art. 28 ff. KI-VO zahlreiche Stellen auf unionaler Ebene eingerichtet werden, die diesen Zweck zentralisiert erfüllen. Zum anderen sollen die Mitgliedstaaten gem. Art. 28 I KI-VO auf nationaler Ebene durch entsprechende Legislation Aufsichtsbehörden einrichten. Die nationalen Aufsichtsbehörden führen die Marktüberwachung innerhalb des Mitgliedstaats durch und dienen als Ansprechpartner für die EU-Behörden.[35]

53 Die Entscheidung über eine deutsche KI-Marktüberwachungsbehörde ist noch nicht getroffen. Hinsichtlich der Auswahl der nationalen Aufsichtsbehörde lässt die KI-VO den Mitgliedstaaten einen großen Freiraum. Die Behörde wird insofern erheblichen Herausforderungen ausgesetzt sein, als dass erstmals eine Software das alleinige Objekt eines Marktüberwachungsvorhabens ist. Die an eine effektive Überwachung zu stellenden Anforderungen weichen aus diesem Grund deutlich von den Anforderungen an die Überwachung analoger Produkte ab, weshalb ein Rückgriff auf erprobte und bewährte Überwachungspraktiken in den meisten Fällen nicht möglich sein wird.

54 Anbieter und Betreiber von KI werden an verschiedenen Stellen der KI-VO dazu verpflichtet, bei den Marktüberwachungsbehörden Meldungen einzureichen oder diesen bestimmte Informationen bereitzustellen. Verstöße gegen diese Anforderungen durch das Unterlassen dieser Mitteilungen oder durch die Angabe von falschen, unvollständigen oder irreführenden Informationen sind gem. Art. 99 V KI-VO mit Bußgeldern von bis zu 7,5 Mio. EUR oder (bei Unternehmen) 1 % des weltweiten Jahresumsatzes bewehrt, je nachdem, was höher ist. Dementsprechend sollte auf der Wahrung der Melde- und Informationspflichten ein besonderes Augenmerk liegen.

V. Ausblick und Handlungsempfehlungen

55 Es gibt fast keine Branche, die in den nächsten Jahren nicht erheblich von KI beeinflusst werden wird. Dementsprechend gibt es kaum ein Unternehmen, das sich nicht mit der KI-VO auseinandersetzen sollte. Wie so oft bieten Zeiten des Wandels sowohl Chancen als auch Risiken, denn wer es schafft, KI effektiv und im Einklang mit den gesetzlichen Anforderungen in seinem Unternehmen einzusetzen, kann dies für Werbezwecke nutzen und einen Marktvorteil ausnutzen. Wer die gesetzlichen Regelungen nicht einhält, muss mit erheblichen Bußgeldern rechnen. Aus diesem Grund ist es entscheidend, sich auf Basis der Vorgaben der KI-VO frühzeitig um die Implementierung der notwendigen Compliance-Management-Systeme zu kümmern. Ergänzend dazu gilt es, die produktbezogenen Vorgaben im Hinblick auf die Entwicklung von KI-Systemen zu dokumentieren.

56 Unternehmen sollten rasch ermitteln, ob sie vom Anwendungsbereich der KI-VO erfasst sind, und klären, welche Art von KI-System sie einsetzen oder zu nutzen planen, um daraufhin die jeweiligen Anforderungen in Erfahrung zu bringen und umzusetzen. Zu beachten sind dabei auch die Umsetzungsfristen sowie etwaige Meldefristen und Vorlaufzeiten für den Kontakt mit Behörden. Des Weiteren sind Vorgaben aus weiteren Gesetzen zu beachten, wie etwa der DS-GVO, dem Data Act sowie der NIS-2-RL.

57 Unternehmen sind gut beraten, bereits frühzeitig eine eigene Inhouse-Expertise im Bereich KI-Compliance aufzubauen oder sich externe Unterstützung zu suchen, um die zahlreichen Anforderungen zu erfüllen.

58 Die ebenfalls äußerst brisanten haftungs-, zurechnungs- und urheberrechtlichen Fragen im Zusammenhang mit KI werden durch die KI-VO nicht geregelt, so dass vertragliche Regelungen in diesem Zusammenhang weiterhin von besonderer Relevanz sind. Auf Unternehmen kommt aufgrund der zahlreichen Anforderungen und notwendigen Prüfungen erheblicher Aufwand zu. Ob die KI-VO die technologische Entwicklung fördert oder ausbremst, wird sich mit der Zeit zeigen. Ebenso spannend ist, welche Auswirkungen die Verordnung auf Drittstaaten hat („Brüssel-Effekt").

---

* Der Autor Chibanguza ist Fachanwalt für Internationales Wirtschaftsrecht und Partner der Luther Rechtsanwaltsgesellschaft mbH. Der Autor Steege arbeitet im Bereich Data Protection in einem Automobilkonzern und ist Lehrbeauftragter an der Universität Stuttgart. Er gibt ausschließlich seine persönliche Rechtsauffassung wieder.

1 COM(2021) 206 final.
2 Rat der Europäischen Union 14954/22 v. 25.11.2022, 2021/0106 (COD).
3 Europäisches Parlament P9_TA (2023) 0236 v. 14.6.2023, 2021/0106 (COD).
4 Steege MMR 2022, 926.
5 OECD Empfehlungen des Rats zu Künstlicher Intelligenz, 2019, S. 5.
6 Vgl. Becker/Feuerstack MMR 2024, 22 (23).
7 Vgl. Ebers LTZ 2024, 1 (1).
8 Zu der Auswirkung dieser Elemente auf die Produzentenhaftung Steege NZV 2021, 6.
9 Kritisch Steege MMR 2022, 926 (928); Steege NZV 2022, 257 (260).
10 Hacker Comments on the Final Trilogue Version of the AI Act v. 23.1.2024, S. 3, abrufbar unter ssrn.com/abstract=4757603.
11 Hacker Comments on the Final Trilogue Version of the AI Act S. 3.
12 Steege/Chibanguza Metaverse-HdB, 2023, § 8 Rn. 94.
13 Vgl. Chibanguza/Schubmann GmbHR 2019, 313 (313 ff.).
14 Brück-Heeb/Oppermann Automatisierte Systeme/Chibanguza, 2022, Kap. 3.12 Rn. 15.
15 Steege/Chibanguza Metaverse-HdB § 8 Rn. 27 f.
16 Bomhard/Merkle RDi 2021, 276 (278).
17 Chibanguza/Steege NWB 2022, 2555 (2561).
18 Frank/Heine NZA 2023, 1281 (1282).
19 Eine derartige Schulungspflicht konnte bislang auch aus Organisationspflichten folgen, Steege Organisationspflichten und Organisationsverschulden, 2022, S. 265.
20 Steege/Chibanguza Metaverse-HdB § 8 Rn. 42.
21 Ebers/Hoch/Rosenkranz/Ruschemeier/Steinrötter RDi 2021, 528 (530).
22 Feuerstack/Becker/Hertz ZfDR 2023, 421 (440).
23 Frank/Heine NZA 2023, 1281 (1283).
24 Hacker Comments on the Final Trilogue Version of the AI Act S. 11.
25 Hacker Comments on the Final Trilogue Version of the AI Act S. 9 f.
26 Feuerstack/Becker/Hertz ZfDR 2023, 421 (426 f.).
27 Spies AI and Data Privacy S. 1 v. 29.1.2024 https://americangerman.institute/2024/01/ai-and-data-privacy.
28 Spies AI and Data Privacy S. 1.
29 Steege/Chibanguza Metaverse-HdB § 8 Rn. 125.
30 Zum Konzept der Technikgestaltung Steege NZV 2023, 12.
31 Ebers LTZ 2024, 1 (1).
32 Ebers LTZ 2024, 1 (1).
33 Hacker Comments on the Final Trilogue Version of the AI Act S. 6.
34 Feuerstack/Becker/Hertz ZfDR 2023, 421 (424).
35 Bomhard/Merkle RDi 2021, 276 (282).

© Verlag C.H.BECK oHG 2024